

CEG 4424/6424 (Security Attacks and Defenses) Homework #5

Question 1 (10 points) Describe the three-way handshake process used to initiate TCP connections.

Answer: The TCP three-way handshake is used to establish a reliable connection between a client and a server. It consists of three steps:

1. SYN (Synchronize): The client sends a SYN packet to the server, indicating a request to establish a connection and providing an initial sequence number.
2. SYN-ACK: The server responds with a SYN-ACK packet, acknowledging the client's request and sending its own sequence number.
3. ACK (Acknowledge): The client sends an ACK packet back to the server, acknowledging the server's sequence number.

After these three steps, the connection is established, and data transfer can begin reliably.

Question 2 (10 points) Explain how TCP SYN flooding attacks work.

Answer: A TCP SYN flooding attack is a type of Denial of Service (DoS) attack that exploits the TCP handshake process and in following (somewhat) manner:

- The attacker sends a large number of SYN requests to a server using spoofed or fake IP addresses.
- The server responds with SYN-ACK packets and allocates resources for each half open connection.
- Since the attacker does not complete the handshake (no final ACK), these connections remain incomplete.
- The server's connection queue becomes full, preventing legitimate users from establishing connections.

This exhausts server resources and effectively denies service to real clients.

Question 3 (10 points) What is misuse detection? Please enumerate at least two advantages of misuse detection compared to anomaly detection.

Answer: Misuse detection (also called signature based detection) identifies attacks by comparing system activity against known attack patterns or signatures.

The advantages over anomaly detection are high accuracy for known attacks, efficient and fast detection, and clear identification of attack type.

Question 4 (10 points) What is anomaly detection? Please enumerate at least one advantage of anomaly detection compared to misuse detection.

Answer: Anomaly detection identifies deviations from normal system behavior by building a baseline of expected activity. Its advantage over misuse detection is that it has the ability to detect unknown (zero day) attacks since it does not rely on predefined signatures.

Question 5 (20 points, for graduate students) Please read the [0x20 paper](#) and answer the following questions. Please use the following notations to represent

- a. The probability for a DNS poisoning attack to be successful when 0x20 is not deployed. (10 Points)
- b. The probability for a DNS poisoning attack to be successful when 0x20 is deployed. (10 Points)

- α = the number of different DNS IDs
- β = the number of source ports
- Υ = the number of source ports excluded (e.g., 1024)
- θ = the number of authority servers
- l = the length of a domain (number of letters)
- m = the number of DNS queries that are simultaneously generated by the attacker.

Answer: Let:

α = number of DNS transaction IDs

β = number of source ports

Υ = excluded ports

θ = number of authoritative servers

l = domain name length

m = number of attacker queries

Now,

- Without 0x20 encoding:
The success probability is:
$$P = 1 - (1 - 1 / (\alpha \cdot (\beta - \Upsilon) \cdot \theta))^m$$

Here, the attacker must correctly guess the transaction ID, source port, and authoritative server.
- With 0x20 encoding:
The success probability becomes:
$$P = 1 - (1 - 1 / (\alpha \cdot (\beta - \Upsilon) \cdot \theta \cdot 2^l))^m$$

0x20 encoding adds entropy by randomizing the case of each letter in the domain name, contributing a factor of 2^l . This makes DNS poisoning significantly harder.

Question 6 (40 points): Please provide a three-page summary of the attached document on the Trusted Platform Module, using 12-point font. Ensure the content is expressed in your own words by rephrasing the original text.

Answer: The Trusted Platform Module (TPM) is a specialized hardware component designed to provide a foundation for secure and trusted computing. It is a tamper resistant module that is typically embedded into a system's motherboard and plays a critical role in ensuring that a computing platform behaves in a predictable and secure manner. While it shares some similarities with smart cards, such as secure processing and storage capabilities, the TPM differs in that it is permanently bound to a specific device rather than being portable. This design allows it to act as a root of trust for the entire system, enabling stronger guarantees about system integrity and security.

The concept of trusted computing revolves around the idea that a system should be able to demonstrate that it is operating as expected. A trusted platform is one that can provide assurance to users or external entities that its behavior has not been compromised. The TPM supports this by acting as a trusted component within the system. It enables the creation of a Trusted Computing Base (TCB), which consists of hardware and software components that are critical to system security. By relying on the TPM, other parts of the system can build upon this trusted foundation.

One of the fundamental roles of the TPM is to provide protected capabilities. These capabilities ensure that sensitive operations, such as cryptographic key management and integrity verification, are carried out in a secure environment. The TPM isolates these operations from the rest of the system, reducing the risk of exposure to malicious software. In addition to protected capabilities, the TPM supports integrity measurement, which involves generating cryptographic hashes of system components. These measurements allow the system to verify whether its software and configuration have been altered.

Integrity reporting is another key function of the TPM. It allows the system to provide proof of its current state to an external party. This is particularly useful in scenarios where trust must be established remotely, such as in secure communications or network access control. By signing integrity measurements with cryptographic keys, the TPM enables other systems to verify that the platform is in a trusted state before interacting with it.

The TPM architecture includes several important components that support its functionality. One of these is non volatile storage, which is used to securely store long term cryptographic keys. Among these keys, the Endorsement Key (EK) is especially important because it uniquely identifies the TPM. The private portion of this key never leaves the device, ensuring that it cannot be compromised. Another critical key is the Storage Root Key (SRK), which serves as the foundation for a hierarchy of keys used to encrypt and protect data.

To preserve user privacy, the TPM uses Attestation Identity Keys (AIKs) instead of directly exposing the Endorsement Key. These AIKs act as pseudonyms, allowing the TPM to authenticate itself without revealing its unique identity. This design helps prevent tracking of the device across different services while still enabling secure verification.

Another essential component of the TPM is the Platform Configuration Registers (PCRs). These registers store measurements of system components taken during the boot process. Each time a component is loaded, its integrity is measured and recorded in a PCR. These measurements are chained together in such a way that any modification to the system will result in a different final value. This makes it possible to detect unauthorized changes and ensures that only trusted software is executed.

The TPM also includes cryptographic engines that support secure operations. These include a random number generator, a hashing engine, and an RSA engine for encryption and digital signatures. These components enable the TPM to perform essential security functions such as key generation, data encryption, and authentication. By integrating these capabilities into hardware, the TPM provides stronger protection than software based solutions.

A unique aspect of the TPM is its ownership model. Unlike many security devices that are preconfigured by manufacturers, the TPM is designed to be controlled by the user. Before it can be fully utilized, the user must take ownership by setting a secret authorization value. This process ensures that only the owner has control over the TPM's functionality. The opt-in nature of this model is important because it gives users the choice to enable or disable trusted computing features according to their preferences.

The concept of roots of trust is central to the TPM's operation. These roots of trust serve as the foundation for all security functions in the system. The Root of Trust for Measurement (RTM) is responsible for measuring system components during the boot process. The Root of Trust for Storage (RTS) ensures that sensitive data and keys are stored securely. The Root of Trust for Reporting (RTR) enables the system to provide reliable information about its state. Together, these roots of trust create a secure environment in which trust can be established and maintained.

During the system boot process, the TPM plays a crucial role in verifying system integrity. The process begins with a trusted component, such as the BIOS, which measures itself and then measures subsequent components before passing control to them. Each measurement is stored in a PCR, creating a chain of trust from the initial boot stage to the operating system and applications. This process ensures that any tampering with system components can be detected early, preventing compromised software from executing.

The TPM also provides mechanisms for secure storage of data. One such mechanism is binding, which encrypts data in a way that only a specific TPM can decrypt it. Another mechanism is sealing, which adds an additional layer of protection by tying data access to the system's state. This means that data can only be accessed if the system is in a specific, trusted configuration. These features are particularly useful for protecting sensitive information such as encryption keys and confidential files.

Attestation is another important service provided by the TPM. It allows the system to prove its integrity to external parties. This is achieved using AIKs, which are certified by trusted authorities. By presenting these certificates along with integrity measurements, the TPM can demonstrate that it is operating in a secure and trusted state. This capability is essential for applications such as secure communications, remote access, and digital rights management.

In conclusion, the Trusted Platform Module provides a comprehensive set of hardware based security features that enhance the trustworthiness of computing systems. By combining secure key storage, integrity measurement, attestation, and user controlled ownership, the TPM establishes a strong foundation for trusted computing. Its ability to detect tampering, protect sensitive data, and verify system integrity makes it a vital component in modern security architectures. As computing systems continue to evolve, the role of the TPM in ensuring security and trust will remain increasingly important.